Team 5 Cyber Incident Report 2

This document contains 2 incidents during the initial report 2 phase.

Incident 1

1. Incident Overview

Date of Report: 2/21/26
Reported By: Team 5 Members

2. Incident Details

Date and Time of Incident: 2/21/26
- Earliest malicious activity observed at 7:31 AM
- Confirmation of the flag stolen at 11:15 AM

Type of Incident: Unauthorized root access via SSH resulting in compromise of the /etc/ blue flag on the WWW server.

3. Detection and Response:

How was the incident detected? The incident was initially identified when the /etc/ blue flag on the WWW server was found missing.

```
find /home/cdc/icdc2026frontend-main/ -newer /etc/blue_flag -type f 2>/dev/null
Feb 21 07:31:48 www.team5.isucdc.com sshd[980701]: Accepted password for root from 49.10.219.164 port 38062 ssh2
Feb 21 07:31:49 www.team5.isucdc.com sshd[980792]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164  user=cdc
Feb 21 07:31:49 www.team5.isucdc.com sshd[980792]: pam_sss(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164 user=cdc
Feb 21 07:31:51 www.team5.isucdc.com sshd[980792]: Failed password for cdc from 49.10.219.164 port 38064 ssh2
Feb 21 07:31:52 www.team5.isucdc.com sshd[980959]: Invalid user alice from 49.10.219.164 port 38078
Feb 21 07:31:52 www.team5.isucdc.com sshd[980959]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164
Feb 21 07:31:54 www.team5.isucdc.com sshd[980959]: Failed password for invalid user alice from 49.10.219.164 port 38078 ssh2
Feb 21 07:31:55 www.team5.isucdc.com sshd[980961]: Invalid user bob from 49.10.219.164 port 56152
Feb 21 07:31:55 www.team5.isucdc.com sshd[980961]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164
Feb 21 07:31:57 www.team5.isucdc.com sshd[980961]: Failed password for invalid user bob from 49.10.219.164 port 56152 ssh2
Feb 21 07:31:59 www.team5.isucdc.com sshd[980963]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164  user=cdc
Feb 21 07:31:59 www.team5.isucdc.com sshd[980963]: pam_sss(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164 user=cdc
Feb 21 07:32:01 www.team5.isucdc.com sshd[980963]: Failed password for cdc from 49.10.219.164 port 56160 ssh2
Feb 21 07:32:02 www.team5.isucdc.com sshd[980966]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164  user=cdc
Feb 21 07:32:02 www.team5.isucdc.com sshd[980966]: pam_sss(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164 user=cdc
Feb 21 07:32:03 www.team5.isucdc.com sshd[980966]: Failed password for cdc from 49.10.219.164 port 56166 ssh2
Feb 21 07:32:05 www.team5.isucdc.com sshd[980969]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164  user=cdc
Feb 21 07:32:05 www.team5.isucdc.com sshd[980969]: pam_sss(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164 user=cdc
Feb 21 07:32:07 www.team5.isucdc.com sshd[980969]: Failed password for cdc from 49.10.219.164 port 55422 ssh2
Feb 21 07:32:08 www.team5.isucdc.com sshd[980972]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=49.10.219.164  user=root
-rw------- 1 cdc cdc 64 Feb 20 20:40 /home/cdc/icdc2026frontend-main/app/.secret_key
f8c9884eaa303097fcd148d3fd689ee3f1cde8323e83df4e58ae36a9373886f8/home/cdc/icdc2026frontend-main/app/__pycache__/auth.cpython-312.pyc
/home/cdc/icdc2026frontend-main/app/__pycache__/__init__.cpython-312.pyc
/home/cdc/icdc2026frontend-main/app/auth.py
/home/cdc/icdc2026frontend-main/app/__init__.py
[cdc@www ~]$
```

The red team successfully SSH'd in as root at 07:31 AM from 49.10.219.164. After getting root, their script kept running and tried cdc, alice, bob, and more (all failed); that's just the automated scanner continuing, but they already had what they needed.

Immediate Actions Taken: We immediately initiated a log review to identify what happened and see how access was gained.

4. Impact Assessment

Systems Affected: WWW

Data Compromised: WWW /etc/ flag. No additional user accounts were successfully accessed.

5. Containment and Eradication

Containment Measures: Terminated all active SSH sessions, changed passwords for root and all local user accounts. We audited /etc/ for unauthorized changes and reviewed active services.

6. Recovery

Recovery Actions: We confirmed there were no unauthorized users that were created. We checked for any cron jobs, suspicious services, unexpected ports, and changed ssh configurations.
Status of Recovery: The blue flag is permanently lost; however, the system is secured and monitored. No ongoing malicious activity has been detected.

7. Root Cause Analysis

Root Cause: The root account password was weak and susceptible to brute-force attack via exposed SSH service.
Contributing Factors: Lack of brute-force protections, insufficient password complexity.

8. Lessons Learned

What went well? Hopefully, we have prevented any future attacks after the additional security measures were made
What could be improved? Root SSH access should have been disabled from the beginning, or the password should have been strengthened. Brute-force protections (rate limiting/monitoring thresholds) should have been active.
Recommendations: Implement account lockout or rate limiting, deploy monitoring alerts for login attempts and events. Also, we should periodically audit authentication logs.

9. Follow-Up Actions

Actions to Prevent Recurrence: Conduct audit across all systems for weak credentials. Add root login monitoring as a standard alert condition.

10. Additional Information

Other Relevant Information:

Incident 2

Password spraying -> WWW, AD,

1. Incident Overview

Date of Report: 2/21/26
Reported By: Coleman Pagac

2. Incident Details

Date and Time of Incident: February 21st, starting at 7:31 AM and ending around ~10:17
Type of Incident: Unauthorized root authentication via SSH resulting in blue flag exfiltration from /etc/

3. Detection and Response:

How was the incident detected? The incident was identified after discovery that the /etc/ blue flag on the WWW server had been accessed/removed. An immediate log review was initiated.

Authentication logs confirm a successful SSH login as root:

```
type=USER_ACCT msg=audit(1771677108.439:101171): pid=980706 uid=0 auid=4294967295 ses=4294967295 msg='op=PAM:accounting grantors=pam_unix acct="root" exe="/usr/lib/systemd/systemd" hostname=? addr=? terminal
=? res=success'
----
time->Sat Feb 21 07:31:48 2026
type=CRED_ACQ msg=audit(1771677108.439:101172): pid=980706 uid=0 auid=4294967295 ses=4294967295 msg='op=PAM:setcred grantors=? acct="root" exe="/usr/lib/systemd/systemd" hostname=? addr=? terminal=? res=fail
ed'
----
time->Sat Feb 21 07:31:48 2026
type=PROCTITLE msg=audit(1771677108.439:101173): proctitle="(systemd)"
type=SYSCALL msg=audit(1771677108.439:101173): arch=c000003e syscall=1 success=yes exit=1 a0=7 a1=7ffcbe5e85a0 a2=1 a3=0 items=0 ppid=1 pid=980706 auid=0 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid
=0 tty=(none) ses=6251 comm="(systemd)" exe="/usr/lib/systemd/systemd" key=(null)
type=LOGIN msg=audit(1771677108.439:101173): pid=980706 uid=0 old-auid=4294967295 auid=0 tty=(none) old-ses=4294967295 ses=6251 res=1
----
time->Sat Feb 21 07:31:48 2026
type=USER_START msg=audit(1771677108.446:101174): pid=980706 uid=0 auid=0 ses=6251 msg='op=PAM:session_open grantors=pam_selinux,pam_selinux,pam_loginuid,pam_keyinit,pam_umask,pam_namespace,pam_keyinit,pam_l
imits,pam_systemd,pam_unix acct="root" exe="/usr/lib/systemd/systemd" hostname=? addr=? terminal=? res=success'
----
time->Sat Feb 21 07:31:48 2026
type=PROCTITLE msg=audit(1771677108.481:101175): proctitle="(systemd)"
type=SYSCALL msg=audit(1771677108.481:101175): arch=c000003e syscall=321 success=yes exit=8 a0=5 a1=7fff9fad3680 a2=90 a3=0 items=0 ppid=1 pid=980706 auid=0 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fs
gid=0 tty=(none) ses=6251 comm="systemd" exe="/usr/lib/systemd/systemd" key=(null)
type=BPF msg=audit(1771677108.481:101175): prog-id=326 op=LOAD
----
time->Sat Feb 21 07:31:48 2026
type=PROCTITLE msg=audit(1771677108.481:101176): proctitle="(systemd)"
type=SYSCALL msg=audit(1771677108.481:101176): arch=c000003e syscall=3 success=yes exit=0 a0=8 a1=7fff9fad3760 a2=90 a3=200000008 items=0 ppid=1 pid=980706 auid=0 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgi
d=0 fsgid=0 tty=(none) ses=6251 comm="systemd" exe="/usr/lib/systemd/systemd" key=(null)
type=BPF msg=audit(1771677108.481:101176): prog-id=326 op=UNLOAD
----
time->Sat Feb 21 07:31:48 2026
type=PROCTITLE msg=audit(1771677108.482:101177): proctitle="(systemd)"
type=SYSCALL msg=audit(1771677108.482:101177): arch=c000003e syscall=321 success=yes exit=8 a0=5 a1=7fff9fad3720 a2=90 a3=4 items=0 ppid=1 pid=980706 auid=0 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fs
gid=0 tty=(none) ses=6251 comm="systemd" exe="/usr/lib/systemd/systemd" key=(null)
type=BPF msg=audit(1771677108.482:101177): prog-id=327 op=LOAD
----
time->Sat Feb 21 07:31:48 2026
type=PROCTITLE msg=audit(1771677108.482:101178): proctitle="(systemd)"
type=SYSCALL msg=audit(1771677108.482:101178): arch=c000003e syscall=3 success=yes exit=0 a0=8 a1=7fff9fad3720 a2=90 a3=4 items=0 ppid=1 pid=980706 auid=0 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgi
d=0 tty=(none) ses=6251 comm="systemd" exe="/usr/lib/systemd/systemd" key=(null)
type=BPF msg=audit(1771677108.482:101178): prog-id=327 op=UNLOAD
----
time->Sat Feb 21 07:31:48 2026
type=CRYPTO_KEY_USER msg=audit(1771677108.487:101179): pid=980712 uid=0 auid=4294967295 ses=4294967295 msg='op=destroy kind=server fp=SHA256:16:21:9f:82:18:80:74:4c:b4:d2:92:dc:d2:10:62:0e:5c:fb:82:1f:86:12:
14:9b:dc:21:ac:44:27:f2:db:9b direction=? spid=980712 suid=0  exe="/usr/sbin/sshd" hostname=? addr=? terminal=? res=success'
----
time->Sat Feb 21 07:31:48 2026
type=CRYPTO_SESSION msg=audit(1771677108.488:101180): pid=980707 uid=0 auid=4294967295 ses=4294967295 msg='op=start direction=from-server cipher=aes128-ctr ksize=128 mac=hmac-sha2-256 pfs=curve25519-sha256@l
ibssh.org spid=980712 suid=74 rport=32886 laddr=10.10.30.10 lport=22  exe="/usr/sbin/sshd" hostname=? addr=12.110.206.207 terminal=? res=success'
----
time->Sat Feb 21 07:31:48 2026
type=CRYPTO_SESSION msg=audit(1771677108.489:101181): pid=980707 uid=0 auid=4294967295 ses=4294967295 msg='op=start direction=from-client cipher=aes128-ctr ksize=128 mac=hmac-sha2-256 pfs=curve25519-sha256@l
ibssh.org spid=980712 suid=74 rport=32886 laddr=10.10.30.10 lport=22  exe="/usr/sbin/sshd" hostname=? addr=12.110.206.207 terminal=? res=success'
----
time->Sat Feb 21 07:31:48 2026
[root@www ~]#
```

Immediate Actions Taken: Changed root password immediately. Reviewed system settings to ensure nothing malicious was placed onto the service.

4. Impact Assessment

Systems Affected: WWW server
Data Compromised: /etc/blue_flag

5. Containment and Eradication

Containment Measures: Implemented brute-force protection.

6. Recovery

Recovery Actions: Confirmed there were no additional SSH systems active, checked for any modified system files, and began enhanced authentication monitoring.
Status of Recovery: Blue flag was compromised and unrecoverable, but the system is secured, and no ongoing activity was observed.

7. Root Cause Analysis

Root Cause: The root account had a weak or default password, and direct SSH root login was enabled. The attacker successfully brute-forced the password prior to the implementation of brute-force protections.
Contributing Factors: Weak password on privileged account and no rate limiting.

8. Lessons Learned

What went well? Rapid log analysis identified the exact compromise vector. No evidence of further exploitation.
What could be improved? Strong password enforcement must occur before exposure to the competition network. We must also enforce brute-force protection.
Recommendations: Enforce strong password complexity policies. Monitor for multiple failed login attempts and successful root authentications.

9. Follow-Up Actions

Actions to Prevent Recurrence: Audit all servers for weak/default credentials. Add credential hardening to the Day 0 deployment checklist.

10. Additional Information

Other Relevant Information: